

Day 4

Day 4: Data Security (Detailed Exam Notes)

1. What is Data Security?

Definition

Data Security means protecting data from:

- Unauthorized access
- Modification
- Theft
- Destruction
- Disclosure

The goal is to keep data:

- **Confidential** (only authorized people can see it)
- **Accurate** (not changed without permission)
- **Available** (accessible when needed)

These three principles are known as the **CIA Triad**:

- **C** = Confidentiality
 - **I** = Integrity
 - **A** = Availability
-

Example

Imagine your university stores students' grades.

Data security ensures:

- Only lecturers can edit grades.
- Students can view only their own grades.

- Hackers cannot steal or modify grades.
 - The system is available during registration.
-

Why is Data Security Important?

Most cybercriminals don't want your computer—they want your **data**.

Examples:

- Credit card numbers
 - Passwords
 - Medical records
 - Company secrets
 - Customer information
-

Important Statistics (Exam)

- **93%** of cyberattacks target data.
- Average data breach cost: **\$4.45 million**.
- Average time to detect a breach: **277 days**.
- **82%** of breaches involve cloud-stored data.

You don't need to memorize every number unless your instructor emphasizes them, but know the general idea.

2. Data Classification

Not all data is equally sensitive.

Organizations classify data to decide how much protection it needs.

Level 0 – Public

Anyone can access it.

Examples

- Company website
- Brochures
- Advertisements

Security

No special protection needed.

Level 1 – Internal

Only employees should access it.

Examples

- Employee directory
- Internal announcements

Security

- Login required
 - RBAC (Role-Based Access Control)
-

Level 2 – Confidential

Sensitive information.

Examples

- Customer information
- Financial reports
- Source code

Security

- Encryption
 - Need-to-Know access
 - Authentication
-

Level 3 – Restricted

Most sensitive information.

Examples

- Social Security Numbers (SSNs)
- Medical records (PHI)
- Credit card data
- Trade secrets

Security

- Encryption
 - MFA
 - DLP
 - Audit logs
-

Easy Memory Trick

Level	Think Of
Public	Everyone
Internal	Employees
Confidential	Managers
Restricted	Top Secret

3. Data States

Data exists in **three different states**.

This is one of the **most common exam questions**.

A. Data at Rest

Definition

Stored data.

Not moving.

Examples

- Hard drives
 - SSD
 - USB flash drives
 - Databases
 - Cloud storage
 - Backups
-

Example

A Word document saved on your laptop.

Nobody is using it.

It is **Data at Rest**.

Threats

- Laptop stolen
- Database hacked
- Backup stolen

Protection

Examples

- BitLocker (Windows)
- FileVault (macOS)
- LUKS (Linux)
- VeraCrypt
- Database encryption

Easy Example

Your phone is locked.

Even if someone steals it,
they cannot read your photos.

That's **Data at Rest protection**.

B. Data in Transit

Definition

Data moving through a network.

Examples

- Sending email
 - Browsing websites
 - Video calls
 - Online banking
-

Threats

- Packet sniffing
 - Man-in-the-Middle (MitM)
 - Session hijacking
-

Protection

- HTTPS (TLS)
 - VPN
 - SSH
 - SFTP
 - IPsec
-

Example

You log into Gmail.

Your password travels across the Internet.

TLS encrypts it.

That protects **Data in Transit**.

C. Data in Use

Definition

Data currently being processed by the CPU or stored temporarily in RAM.

Example

You open Microsoft Word.

The document loads into RAM.

Now it is **Data in Use**.

Threats

- RAM scraping
- Malware
- Side-channel attacks
- Process injection

Protection

- Secure Enclaves
- Confidential Computing
- Homomorphic Encryption

Easy Memory Trick

State	Think
At Rest	Stored
In Transit	Moving
In Use	Processing

4. Cryptography

Cryptography means

Protecting information using mathematics.

Plaintext



Encryption



Ciphertext



Decryption



Original Message

Example

Original

HELLO

Encrypted

9dk2L@x7#

Only someone with the correct key can decrypt it.

5. Symmetric Encryption

Uses **ONE key**.

Same key encrypts and decrypts.

Encrypt



Secret Key



Decrypt

Example

Alice and Bob both know the password

Blue123

Alice encrypts a file.

Bob uses the same password to decrypt it.

Advantages

Very fast.

Efficient for large files.

Disadvantages

How do Alice and Bob securely share the secret key?

This is called the **Key Distribution Problem**.

AES

The most widely used symmetric encryption algorithm.

Key sizes

- AES-128
- AES-192

- AES-256 (strongest standard option)
-

Where is AES Used?

- Wi-Fi (WPA2/WPA3)
 - BitLocker
 - HTTPS
 - VPNs
 - File encryption
-

AES Modes

ECB

× Never use.

Problem

Identical plaintext blocks produce identical ciphertext blocks, revealing patterns.

CBC

Better than ECB.

Requires an Initialization Vector (IV).

Still has implementation pitfalls if not used correctly.

GCM

□ Best choice.

Provides:

- Encryption
- Integrity
- Authentication

This is called **Authenticated Encryption with Associated Data (AEAD)**.

Exam Tip

Remember

AES-GCM = Recommended

6. Asymmetric Encryption

Uses **two keys**.

Public Key

Private Key

Public Key

Can be shared with everyone.

Private Key

Must remain secret.

Example

Bob wants people to send him secret messages.

Bob publishes

Public Key.

Alice encrypts with Bob's Public Key.

Only Bob's Private Key can decrypt the message.

Algorithms

RSA

Based on prime factorization.

Minimum recommended size:

2048 bits.

ECC (Elliptic Curve Cryptography)

Smaller keys.

Faster.

Provides similar security to RSA with much shorter key sizes.

Used in modern systems and mobile devices.

Diffie-Hellman

Purpose

Securely exchange a shared secret key over an insecure network.

It is **not** used to encrypt data directly.

Easy Comparison

Symmetric	Asymmetric
One key	Two keys
Fast	Slower
AES	RSA, ECC
Encrypts data	Key exchange, signatures

Hybrid Encryption

This is how HTTPS (TLS) works.

Step 1

RSA or ECC securely exchanges a session key.

Step 2

AES encrypts all the website traffic.

This combines the strengths of both methods.

7. Hashing

A hash converts data into a **fixed-size value**.

It is a **one-way function**.

You cannot recover the original data from the hash.

Example

Hello

↓

185F8DB3...

Even changing one letter creates a completely different hash.

Hash Properties

One-way

Cannot reverse the hash.

Deterministic

Same input → Same output.

Avalanche Effect

Small input change → Huge output change.

Example

HELLO

Hash A

8D83...

hello

Hash B

F98C...

Completely different.

Collision Resistance

It should be extremely difficult to find two different inputs that produce the same hash.

Broken Hash Algorithms

× MD5

× SHA-1

They have known collision attacks.

Secure Hash Algorithms

- SHA-256
 - SHA-384
 - SHA-512
 - SHA-3
 - BLAKE2
-

Password Hashing

Never store passwords as plain text.

Store

Password

↓

Salt

↓

Hash

Salt

Random data added before hashing.

Stops attackers from using precomputed rainbow tables.

Password Hashing Algorithms

Best

- Argon2id

Also common

- bcrypt
- PBKDF2

These are intentionally slow to make password cracking harder.

8. Digital Signatures

Purpose

Prove:

- Integrity
 - Authenticity
 - Non-repudiation
-

How It Works

Sender

1. Hashes the message.
2. Encrypts the hash with their **Private Key**.

Receiver

1. Decrypts the signature using the sender's **Public Key**.
2. Hashes the received message.
3. Compares the two hashes.

If they match:

The message is authentic and unchanged.

Easy Example

Teacher signs a certificate.

Anyone can verify the signature.

Nobody else can create the same valid signature because only the teacher has the private signing key.

9. PKI (Public Key Infrastructure)

PKI manages digital certificates.

Certificate Authority (CA)

Trusted organization that issues certificates.

Examples include commercial CAs trusted by browsers.

Registration Authority (RA)

Verifies identities before a certificate is issued.

Certificate

Contains

- Public Key
- Owner's identity
- Expiration date
- CA signature

Trust Chain

Root CA

↓

Intermediate CA

↓

Website Certificate

Browsers verify this chain before trusting a website.

10. Key Management

Encryption is useless if attackers steal the keys.

Key Lifecycle

Generate

↓

Store

↓

Distribute



Rotate



Revoke



Destroy

Storage

Examples

- HSM (Hardware Security Module)
 - TPM (Trusted Platform Module)
 - Cloud KMS
-

Rotation

Replace keys regularly or after a defined usage period.

Revocation

Immediately invalidate compromised keys.

Destruction

Delete keys securely.

Encrypted data becomes unreadable without the key.

11. Data Masking

Hides part of the information while keeping the format recognizable.

Example

Original

```
4111 1111 1111 1234
```

Masked

```
XXXX XXXX XXXX 1234
```

Used for customer service and testing.

12. Tokenization

Sensitive data is replaced with a meaningless token.

Example

Original

```
4111111111111234
```

Token

```
TK93821AB
```

The real card number is stored safely in a secure token vault.

Difference

Masking

Hides data visually.

Tokenization

Replaces data completely.

13. Data Loss Prevention (DLP)

Purpose

Prevent sensitive information from leaving the organization.

Example

Employee tries to email:

Credit Card Numbers

DLP detects the pattern.

Blocks the email.

Types

- Endpoint DLP
 - Network DLP
 - Cloud DLP
-

14. Data Destruction

When disposing of storage devices, data must not be recoverable.

Overwriting

Write new data over the old data.

Degaussing

Uses a strong magnetic field.

Works only on magnetic media like HDDs and tapes.

Does **not** work on SSDs.

Physical Destruction

- Shredding
 - Crushing
 - Incineration
-

Cryptographic Erasure (Crypto-Shredding)

Destroy the encryption key.

Without the key,

the encrypted data is permanently unreadable.

15. Compliance Standards

GDPR

European Union privacy regulation.

Key points:

- User consent
 - Right to be forgotten
 - 72-hour breach notification
-

HIPAA

United States law protecting electronic health information (ePHI).

Used by hospitals and healthcare providers.

PCI-DSS

Security standard for organizations that process or store payment card data.

Used by banks, online stores, and payment processors.

16. OpenSSL Lab (What It Does)

```
openssl rand -hex 32 > secret.key
```

Creates a random 256-bit encryption key.

```
openssl enc -aes-256-cbc -salt -in sensitive.txt -out sensitive.enc -pass file:./secret.key
```

Encrypts `sensitive.txt` using AES-256.

```
openssl enc -d -aes-256-cbc -in sensitive.enc -out decrypted.txt -pass file:./secret.key
```

Decrypts the encrypted file back to its original content.

```
sha256sum filename
```

Calculates a SHA-256 hash so you can verify the file hasn't changed.

Quick Exam Memory Table

Topic	Remember
Data at Rest	Stored data (HDD, SSD, database)
Data in Transit	Moving across a network
Data in Use	Being processed in RAM/CPU
Symmetric Encryption	One shared key (AES)
Asymmetric Encryption	Public key + Private key (RSA, ECC)
Hybrid Encryption	RSA/ECC exchanges the key, AES encrypts the data
Hashing	One-way, fixed-size output
Salt	Random value added before password hashing
Digital Signature	Integrity + Authenticity + Non-repudiation
PKI	Manages certificates and trust
AES-GCM	Recommended AES mode
ECB	Never use; reveals patterns
Data Masking	Hide part of the data
Tokenization	Replace data with a token
DLP	Prevent sensitive data from leaving
GDPR	EU privacy regulation
HIPAA	Healthcare data protection
PCI-DSS	Payment card security

High-Probability Exam Questions

1. What are the three states of data?

- At Rest (stored), In Transit (moving), In Use (being processed).

2. What is the difference between symmetric and asymmetric encryption?

- Symmetric uses one shared key and is fast (AES).
- Asymmetric uses a public/private key pair and is slower (RSA, ECC).

3. Why is hybrid encryption used in HTTPS?

- Asymmetric encryption securely exchanges the session key, then symmetric encryption efficiently encrypts the data.

4. What is the difference between encryption and hashing?

- Encryption is reversible with the correct key.
- Hashing is one-way and used for integrity checks and password storage.

5. Why should passwords be salted?

- To prevent rainbow table attacks and ensure identical passwords produce different hashes.

6. What security services do digital signatures provide?

- Integrity, Authenticity, and Non-repudiation.

7. What is the difference between data masking and tokenization?

- Masking hides part of the original value.
- Tokenization replaces the value with a meaningless token while storing the real value securely elsewhere.

8. Which AES mode is recommended? Which should never be used?

- **AES-GCM** is recommended.
- **ECB** should never be used because it leaks patterns in the plaintext.